EXAMLOC V2

Current Project Status

Implementation and Verification Dossier

A complete evidence-based account of the upgrade roadmap, current architecture, implemented controls, automated verification, performance measurements, biometric evaluation, limitations, and remaining product work.

Document control	Value
Document date	16 September 2026
Repository branch	main
Base commit	7783638d4268164d717aaa063f1519a72cef11b9
Working tree	Dirty - verified changes in this report are not yet committed
Threshold	FACE_SIMILARITY_THRESHOLD=0.40 (unchanged)
Classification	Engineering and research status report; not production certification

Accuracy note: 'complete' in this report means implemented and supported by the listed inspection or tests. It does not mean independently audited, legally certified, or validated for every deployment environment.

Contents

Contents 2

1. Executive summary 4

Evidence categories . . . 4

2. Upgrade roadmap status 5

3. Current system architecture 6

Runtime topology . . . 6

Trust model . . . 6

4. Security and authorization hardening 7

Authentication and token model . . . 7

Ownership and isolation controls . . . 7

5. Exam reliability and asynchronous processing 8

Server-authoritative completion . . . 8

Asynchronous grading . . . 8

Answer resilience and deterministic presentation . . . 8

6. Biometric lifecycle, privacy and evidence 9

Encryption implementation facts . . . 9

7. Database, migrations and codebase refactoring 10

Database and migrations . . . 10

Frontend decomposition results . . . 10

8. Automated verification evidence 11

Backend coverage represented by passing tests . . . 11

Remaining frontend lint warnings (all non-error) . . . 12

9. Local API and login performance evidence 13

All retained aggregate runs . . . 13

Interpretation . . . 13

10. Controlled biometric threshold evaluation 14

Dataset and protocol . . . 14

Operational exclusions . . . 14

Decision . . . 14

Limitations . . . 14

11. Face-worker throughput evaluation 15

Interpretation . . . 15

12. Session-level repeated-observation research 16

Interpretation and decision . . . 16

13. Documentation alignment completed 17

Claims policy now documented . . . 17

14. Known limitations, unresolved work and risk register 18

Repository-state limitation . . . 18

Docker validation limitation . . . 18

15. Recommended next sequence 19

Appendix A. Current changed/untracked scope 20

Tracked modifications at report time . . . 20

Untracked additions at report time . . . 20

Appendix B. Verification commands and outcomes 21

Appendix C. Evidence and source registry 22

Appendix D. Metric definitions 23

End of report . . . 23

1. Executive summary

ExamLoc has moved from a completed academic prototype toward a substantially hardened v2 engineering baseline. Roadmap stages 1-4 are implemented, stage 5 has reproducible harnesses and retained biometric/session-policy evidence, and stage 6 documentation alignment is complete. Product-level examiner risk summaries, evidence export, broader operations work, and prospective biometric validation remain next-stage work.

IMPLEMENTED	Security, authorization, server-side completion, asynchronous grading, biometric privacy controls, core refactoring, and automated regression coverage.
MEASURED	Local API load behavior, controlled FEI threshold accuracy, isolated face-worker throughput through 25 simulated students, and offline repeated-observation policies.
NOT CHANGED	The production face-distance threshold remains 0.40. Offline session-policy candidates are not deployed.
REMAINING	Product-level risk summaries, incident export, prospective consented validation, rate limiting, security-header hardening, operational alerting, backup/restore drills, and warning cleanup.

Fresh verification on 16 September 2026: 63/63 backend tests passed, 13/13 frontend tests passed, 11/11 evaluation-harness tests passed, TypeScript passed, ESLint completed with zero errors and 61 warnings, Git whitespace validation passed, and docker-compose.yml parsed successfully.

Evidence categories

- Verified implementation: inspected source code plus automated regression tests.
- Reproducible empirical evidence: retained aggregate reports with methods, sample counts, and limitations.
- Preliminary local evidence: raw ignored benchmark outputs, reported without general production claims.
- Known limitation: documented gap or uncertainty that has not been concealed by a completion label.

2. Upgrade roadmap status

#	Roadmap area	Status	Implemented and verified	Outstanding boundary
1	Security and authorization	Complete	Admin ownership enforcement; protected results, sessions, violations, evidence and monitoring WebSocket; student session scope; signed enrollment binding; role validation.	No external penetration test; production rate limiting remains.
2	Server-side completion	Complete	Persisted expected_end_time; minute-level Celery Beat reconciliation; abandoned expired sessions finalized; ungraded submissions recovered.	Operational alerting and disaster drills remain.
3	Asynchronous grading	Complete	Submission commits before queue dispatch; grading worker; retry behavior; idempotent grading; recovery after broker failure.	Capacity planning remains environment-specific.
4	Biometric privacy and evidence	Complete	Clean frames discarded; violation evidence deduplicated; scheduled expiry; encrypted templates; server-side verification authoritative.	Institutional retention/consent policy still required for deployment.
5	Database and migrations	Substantial	Encrypted TEXT template model; authoritative backend Alembic head; env-driven credentials; migration tests.	Legacy root alembic and 'backend/alembic 2' directories still exist and should be archived/removed deliberately.
6	Frontend/backend refactoring	Substantial	Student exam hooks/components; admin exam workspace; institution page; audit page; QuestionManager; structured backend logging.	Exam entry gate remains 564 lines; 61 lint warnings remain in unrelated files.
7	Automated testing	Complete baseline	Core lifecycle, cross-session access, tenant isolation, timing, grading, encryption, retention, migrations, logging, and key frontend interactions.	Not full line/branch coverage; no comprehensive browser E2E suite.
8	Performance and biometric evaluation	Substantial	Locust API/login harness; FEI calibration/held-out threshold report; face-worker harness; repeated-observation simulation.	Face-worker 25-user level has one run; 50/100 not run; API results are local, not production capacity.
9	Documentation alignment	Complete	Root/backend/frontend/performance docs describe JWTs, enrollment, encryption, retention, design decisions, reproducibility, and limitations accurately.	Must be maintained as implementation changes.
10	Product-level improvements	Next stage	Audit workflow already supports event and evidence review; analytics exist.	Risk summaries, prioritized review, incident export and broader system-health analytics remain.

Overall current level: hardened engineering/research baseline with verified core controls and reproducible evaluation tooling; not yet a production-certified or fully productized platform.

3. Current system architecture

Runtime topology

Component	Technology / queue	Responsibility	Authoritative data
Frontend	Next.js 16.2.3, React 19.2.4, TypeScript	Admin workspaces, enrollment, exam entry/shell, monitoring, audit, analytics	None; client state is non-authoritative
API	FastAPI 0.135.3 / Uvicorn	HTTP, signed cookies/tokens, role and ownership validation, authenticated WebSockets	Reads/writes PostgreSQL
Database	PostgreSQL 16 / SQLModel / SQLAlchemy	Institutions, exams, enrollment, sessions, answers, results, violations, snapshot metadata	Yes
Broker	Redis 7	Celery broker and temporary results	No
Face worker	Celery queue: face; solo concurrency 1 locally	Decode, detect, encode, compare, record anomalies	Writes violation/evidence metadata to PostgreSQL
Grading worker	Celery queue: grading	Autograding, timeout recovery, evidence cleanup	Writes PostgreSQL
Email worker	Celery queue: default	Enrollment, exam and result email delivery	No authoritative exam state
Scheduler	Celery Beat	Expired-session job every 60 s; evidence cleanup every 3600 s	Schedules tasks only
Evidence store	MinIO; local fallback in development	Retained violation snapshots	Binary evidence only; metadata in PostgreSQL

Trust model

- PostgreSQL is authoritative for exam state, timing, answers, submission and grading; Redis restarts must not erase exam state.
- The backend validates authorization, ownership, deadlines, identity scope and score changes. UI controls are not security boundaries.
- Server-side biometric processing is authoritative; the browser only captures and submits frames.
- A violation is an event for review, not proof of misconduct and not an automatic disciplinary conclusion.

4. Security and authorization hardening

Authentication and token model

- Examiner and student access tokens are signed JWTs using separate secrets selected from the role claim.
- Student exam JWTs include student subject, exam_uid, session_uid, role, jti and expiry; protected routes match all relevant scopes.
- Email verification, password reset and enrollment handoffs use URL-safe timed signatures with role-appropriate secrets and salts.
- Admin routes require authenticated admin role; sensitive HTTP routes and examiner monitoring WebSockets reject missing or incorrect authorization.

Ownership and isolation controls

- Institution and exam ownership checks protect questions, enrollment, students, results, sessions, analytics, violations and evidence.
- Bulk question deletion and bulk unenrollment authorize the entire batch before mutation.
- Answer requests cannot override the token's session; options from other questions are rejected.
- Cross-student and foreign-admin resources are hidden as not found where appropriate to reduce resource disclosure.
- Face registration resolves the target enrollment exclusively from a signed face-registration token; arbitrary client enrollment identifiers are not accepted.

Fresh test evidence: 10 admin tenant-isolation tests, 13 exam-session authorization tests, and 7 face-enrollment authorization tests are included within the passing 63-test backend suite.

5. Exam reliability and asynchronous processing

Server-authoritative completion

- start_exam calculates expected_end_time and caps it at the exam's closing time.
- Answer saves cannot race past the authoritative deadline.
- Late submission uses the persisted deadline rather than browser time.
- Celery Beat scans in-progress sessions every minute and finalizes eligible sessions at their own expected deadlines.
- The reconciliation task also recovers submitted-but-ungraded sessions.
- The frontend timer displays the backend deadline and keeps a session-storage copy only for refresh continuity.

Asynchronous grading

- Submission state is committed before asynchronous grading dispatch.
- A broker failure after commit does not lose the submitted state; the periodic recovery path can enqueue grading later.
- Grading runs in the grading queue, persists per-answer correctness and the weighted score, and does not regrade an already graded session.
- Celery uses late acknowledgements and rejects work on worker loss; task retry behavior is configured per task type.

Answer resilience and deterministic presentation

- Frontend answer saving retries transient failures up to three attempts with a 500 ms delay.
- Saved answers are loaded from PostgreSQL when the exam workspace is restored.
- Question order is deterministically shuffled from student_uid and exam_uid; option order is deterministically shuffled from student_uid and question_uid when enabled.

6. Biometric lifecycle, privacy and evidence

Stage	Current behavior	Privacy / integrity property
Enrollment authorization	Signed token resolves the exact enrollment and exam window.	Client cannot select an arbitrary enrollment.
Capture	Request accepts 3-5 base64 images; normal UI captures five.	At least 3 must pass by default.
Quality	Decode, brightness, blur and exactly-one-face checks.	Rejected images are not averaged.
Template	Passing 128-dimensional embeddings are averaged.	Multi-image representation reduces reliance on one capture.
Storage	Averaged vector encrypted with AES-256-GCM using a random nonce and versioned format.	Plaintext embedding is not persisted; tampering is rejected.
Verification	Live embedding is compared by Euclidean distance; match when distance < 0.40.	Threshold is environment-driven and unchanged.
Clean frame	Successful frame is discarded after verification.	No clean snapshot retained.
Violation	no_face, multiple_faces or face_mismatch creates an event.	First image per type/session retained; repeats increment count.
Retention	Hourly cleanup removes expired, inline legacy or unclassified snapshots.	Default retention is 7 days; failed storage deletion leaves the DB row for retry.
Access	Snapshot proxy requires authorized exam ownership and hides clean/expired rows.	Evidence is not a public object URL.

Encryption implementation facts

- ENCRYPTION_KEY must be a 64-hex-character, 256-bit key.
- AES-GCM additional authenticated data identifies the v1 face-embedding format.
- Legacy numeric arrays can be read only during migration compatibility; new writes are encrypted text.
- The migration converts existing arrays and preserves existing templates without mandatory re-enrollment.
- Logs intentionally exclude embeddings, tokens, passwords, AES keys, raw captures and biometric distances.

7. Database, migrations and codebase refactoring

Database and migrations

- backend/alembic.ini and backend/alembic/ are treated and tested as the authoritative migration configuration/history.
- The current authoritative history contains 14 revision files and one tested head.
- Migration c7f2a9d4e6b1 converts face embeddings to encrypted TEXT while preserving legacy data.
- Database, Redis, JWT, MinIO, SMTP, biometric and encryption settings are environment-driven; .env.example now uses the correct local Compose host 'postgres'.
- COOKIE_SECURE is wired into the API Compose service; false is local HTTP only and production must use true behind HTTPS.
- Known cleanup debt: stale root migration material and backend/alembic 2 remain in the working tree and should be archived or removed only after confirming no deployment depends on them.

Frontend decomposition results

Area	Before	Current coordinator	Extracted responsibilities
Student exam shell	~710 lines (historical)	237 lines	Timer, answer sync, browser violations, webcam, WebSocket, header, navigation, question display, proctoring panels, overlays
Institution workspace	~628 lines	57 lines	Workspace hook, types, header, tabs, exams, students, subjects, analytics
Session audit	~633 lines	75 lines	Audit hook/types, navigation, candidate summary, sidebar, event log, snapshots, violation config
Question manager	523 lines	166 lines	Question hook/types, editor, bulk upload, list and focused test

- Pages now coordinate route and view state; hooks own remote state and mutations; focused components render local concerns; shared types define contracts.
- Existing API endpoints and user-visible workflows were preserved during the latest refactor.
- Arbitrary institution logos and authenticated evidence images intentionally retain narrowly scoped raw image behavior where Next image optimization could break remote/authenticated sources.
- The public exam-entry gate remains 564 lines and is the next obvious frontend extraction candidate, though it was outside the targeted roadmap refactors completed in this session.

8. Automated verification evidence

Check	Result	Date	Scope / note
Backend unittest	63/63 passed	2026-09-16	9 test modules; 1.450 s; authorization, lifecycle, completion, crypto, migration, logging, evidence
Frontend Vitest	13/13 passed	2026-09-16	7 test files; 18.27 s; refactored workspaces, question list, exam admin helpers/state
Evaluation harness unittest	11/11 passed	2026-09-16	Threshold math, strict decision rule, percentiles, repeated-observation policy logic
TypeScript	Passed	2026-09-16	tsc --noEmit
ESLint	0 errors, 61 warnings	2026-09-16	Command exit 0; warnings documented below
Git whitespace	Passed	2026-09-16	git diff --check
Compose YAML	Parsed	2026-09-16	PyYAML parse passed; Docker Compose CLI plugin crashed independently

Backend coverage represented by passing tests

- Every admin route requires authentication/admin role; institution/exam/question ownership boundaries; batch authorization before mutation.
- Embedding encryption round trip, random nonce, dimensional validation, tamper rejection, encrypted model column and encryption before DB write.
- Start, answer create/update, submit, deadline enforcement, async dispatch ordering, idempotent grading and periodic recovery.
- Cross-student resource protection; examiner and student WebSocket authentication; answer-body scope cannot override token scope.
- Signed face-registration token behavior, expiry/window checks, missing/mismatched enrollment rejection and client biometric-field rejection.
- No print calls in application modules; sensitive SMTP failure logs exclude recipient/message content.
- One authoritative migration head; embedding migration preservation.
- No snapshot for a clean match; evidence deduplication; retention cleanup; storage-failure retry behavior; clean/expired evidence hidden.

Remaining frontend lint warnings (all non-error)

File	Warnings	Main categories
dashboard/analytics/page.tsx	10	Unused icon imports and unused colorClasses
pre-enroll/page.tsx	3	Unused imports and catch variable
subject detail page	3	Unused imports; missing hook dependency
institutions/page.tsx	3	Unused imports; raw image warning
dashboard/page.tsx	4	Unused imports/variable
settings/page.tsx	2	Unused import/variable
subject-name page	5	Unused values; missing dependency; two raw image warnings
subjects/page.tsx	1	Unused import
exam entry gate	5	Unused imports/variable; missing dependency; raw captured-image warning
forget-password	4	Unused imports/variable
guide + layout	3	Unused import/font values
reset-password	4	Unused imports/variable
verify-email	2	Unused imports
TopViolatorsList + login + signup	3	Unused imports
CreateExamModal	2	Unused import; missing hook dependency
CreateInstitutionModal	3	Unused values; raw image warning
Sidebar	3	Unused imports
lib/api.ts	1	Unused catch variable
Total	61	0 ESLint errors

9. Local API and login performance evidence

Environment recorded for the retained Locust results: macOS 13.7.8, Intel Core i5-7360U 2.30 GHz, 4 CPU cores, 8 GiB host RAM, Docker allocation 4 CPUs / 4.105 GB, Locust 2.46.5 on Python 3.14.4. The environment record is dated 14 September 2026 at commit 9b4e8917253c05d88548e0157409fb84ede2fad3.

All retained aggregate runs

Scenario	Req	Fail	Med ms	Avg ms	p95	p99	Max	RPS
admin-login-1-per-second	177	0	130	245.2	840	1400	1400	0.99
admin-read-100-preauth-run1	9264	0	920	1110.4	2600	4100	11000	30.95
admin-read-100-run1	12629	0	170	346.3	1000	3200	14000	42.43
admin-read-100-steady-run1	13824	0	320	459.9	1300	1800	4300	40.74
admin-read-25-preauth-baseline	3679	0	12	24.8	51	280	1500	12.35
admin-read-50-diagnostic	5405	0	21	133.5	840	1800	5000	23.45
admin-read-50-preauth-run1	6778	0	23	164.2	1100	2500	3900	22.68
admin-read-50-steady-run1	8368	0	23	105.0	530	1500	5900	23.96
admin-read-medium-run1	3674	0	14	27.2	48	390	1700	12.32
admin-read-small-run1	1437	0	14	87.0	71	760	9200	4.83
admin-read-small-run2	1456	0	12	18.4	40	160	310	4.88
admin-read-small-run3	1493	0	12	17.5	35	140	360	5.00
admin-read-smoke-1user-1min-run2	29	0	12	19.3	54	150	150	0.51
admin-read-smoke-run3	31	0	12	20.3	59	150	150	0.54
admin-read-smoke	29	0	15	56.8	290	670	670	0.51

Interpretation

- Every retained Locust aggregate above recorded zero request failures. That demonstrates scenario correctness in these runs, not unlimited capacity.
- Three small runs show a warm/cold effect: run 1 average 87.0 ms and max 9.2 s versus run 2 average 18.4 ms and run 3 average 17.5 ms.
- The 25-user pre-auth baseline completed 3,679 requests at 12.35 RPS with 24.8 ms average, 51 ms p95 and 280 ms p99.
- At 50-user scenarios, average latency ranged from 105.0 to 164.2 ms and p95 from 530 to 1,100 ms, depending on run shape.
- At 100-user scenarios, throughput reached 30.95-42.43 RPS while average latency rose to 346.3-1,110.4 ms and p95 to 1,000-2,600 ms. This is clear local degradation without request failure.
- The isolated paced login run achieved 0.994 logins/s: 177 requests, zero failures, 245.2 ms average, 840 ms p95 and 1.4 s p99/max.
- Earlier mixed login/read output showed login latency dominating aggregates; the harness therefore separates setup authentication and provides a dedicated login scenario.
- Spot docker stats during high load showed the API around 52-127% CPU and approximately 110 MiB memory; PostgreSQL around 8-41% CPU and 30-48 MiB; Redis around 3% CPU and 9.6 MiB. These were screenshots, not synchronized time-series measurements.

Publication boundary: these runs were executed on one developer laptop with local containers and synthetic data. They are not production capacity, SLA, or scalability guarantees. A formal report should repeat equivalent runs at least three times, retain environment/resource telemetry, and report the median and observed range.

10. Controlled biometric threshold evaluation

Dataset and protocol

- FEI Face Database original-image archives; research-use source restrictions prohibit redistribution/reproduction.
- 2,800 validated unique JPEGs, 200 identities, 14 images per identity.
- Per identity: images 03, 05, 07, 11 and 12 formed the averaged enrollment template; nine other images were probes.
- Identity-disjoint calibration subjects 001-100 and held-out subjects 101-200.
- Production decode, quality checks, 128-dimensional encoder, multi-image averaging, Euclidean distance and strict match rule distance < threshold.
- No-face and multiple-face results were operational exclusions, reported separately from FAR/FRR denominators.

Split	Threshold	Genuine	False reject	FRR	Impostor	False accept	FAR
Calibration	0.40	821	140	17.0524%	81,279	15	0.0185%
Calibration	0.47	821	80	9.7442%	81,279	33	0.0406%
Held-out	0.40	807	138	17.1004%	79,893	0	0.0000% observed
Held-out	0.47	807	93	11.5242%	79,893	43	0.0538%

Operational exclusions

- Calibration: 500 enrollment submissions, 499 passing; 900 probes, 821 detected; 80 exclusions comprising 79 no-face probes and one multiple-face enrollment outcome.
- Held-out: 500 enrollment submissions, 500 passing; 900 probes, 807 detected; 93 exclusions, all no-face probes (10.33% of submitted probes).

Decision

- 0.40 is strict, not lenient. Its held-out genuine rejection rate was approximately 17.10% among detected genuine probes.
- 0.47 reduced held-out false rejects by 45 events and 5.5762 percentage points, but introduced 43 false accepts and 0.0538% observed FAR.
- Zero held-out false accepts at 0.40 means zero observed in this finite run; it does not prove zero population risk.
- The production threshold remains 0.40. This evaluation alone does not authorize a change.

Limitations

- Controlled white-background images; mainly FEI students/staff aged 19-40; not representative of every deployment population.
- Extreme profile and low-light probes stress detection; pairwise impostor comparisons are not all statistically independent.
- No demographic subgroup analysis; results are model/preprocessing/dataset specific; per-probe rather than live sequential sessions.

11. Face-worker throughput evaluation

The isolated benchmark uses the production decoder, detector/encoder and distance calculation on the dedicated face-benchmark queue. It cannot create violations, write snapshots, modify sessions, or read/write application database rows. It excludes API authentication, database lookup, embedding decryption and evidence writes.

Run	Stu	Req t/s	Sub	Done	Fail	No face	Peak	Q p95	Proc p95	E2E p95	E2E max	Done/s
fei-1-student-smoke	1	0.1	6	6	0	0	1	31.9	230.4	257.7	261.3	0.100
fei-10-students-run1	10	1.0	180	180	0	16	1	45.1	308.7	350.8	565.6	1.000
fei-10-students-run2	10	1.0	180	180	0	16	1	31.4	276.5	298.2	377.1	1.000
fei-10-students-run3	10	1.0	180	180	0	16	1	22.2	206.2	231.2	418.2	1.000
fei-25-students-run1	25	2.5	450	450	0	32	3	27.4	209.6	246.3	798.0	2.500
fei-5-students-run1	5	0.5	90	90	0	6	1	38.3	362.9	399.9	837.1	0.500
fei-5-students-run2	5	0.5	90	90	0	6	1	31.0	223.3	257.6	439.5	0.500
fei-5-students-run3	5	0.5	90	90	0	6	1	25.5	206.6	256.5	666.8	0.500

Interpretation

- Smoke: 6/6 tasks completed at 0.1 task/s; zero failures; 257.7 ms worker E2E p95.
- Five students: each of three runs completed 90/90 tasks at approximately 0.5 task/s with zero failures. Median across runs: queue p95 31.0 ms, processing p95 223.3 ms, worker E2E p95 257.6 ms.
- Ten students: each of three runs completed 180/180 tasks at approximately 1 task/s with zero failures. Median across runs: queue p95 31.4 ms, processing p95 276.5 ms, worker E2E p95 298.2 ms.
- Twenty-five students: one run completed 450/450 tasks at 2.500 tasks/s with zero failures, queue p95 27.4 ms, processing p95 209.6 ms and worker E2E p95 246.3 ms; peak in-flight was 3.
- No-face outcomes are dataset/detector outcomes, not task failures: 6/90 at five students, 16/180 at ten students, and 32/450 at twenty-five students.
- The 25-student level has not met the protocol's three-run requirement; 50 and 100 students have not been run. No production capacity claim is justified yet.
- All recorded summaries used commit 7783638d4268164d717aaa063f1519a72cef11b9 with a dirty working tree, seed 20260916, one warm-up task, a 10 s capture interval and local Redis DB 15.

12. Session-level repeated-observation research

This was an offline simulation using held-out FEI observations. It did not change the API, worker, database, evidence store or threshold. Each seed simulated 10,000 genuine and 10,000 impostor sessions, nine observations per session, using seeds 20260916, 20260917 and 20260918.

Policy	Genuine alert	Impostor detection	Median obs	p95 obs
Single anomaly	98.13% (98.10-98.16%)	100.00%	1	1
Two consecutive mismatches	12.25% (12.10-12.36%)	100.00%	2	4
Three consecutive mismatches	0.68% (0.66-0.76%)	99.46% (99.39-99.48%)	3	6
Three mismatches in five	1.94% (1.90-2.17%)	100.00%	3	5

Interpretation and decision

- Treating one anomaly as a definitive session alert produced an unusably high simulated genuine-session alert rate.
- Three consecutive mismatches minimized genuine alerts but missed approximately 0.52-0.61% of simulated impostor sessions within nine observations.
- Three mismatches in five detected all simulated impostor sessions and did so by observation five at p95, but its genuine alert rate was about three times the three-consecutive policy.
- No-face should first drive capture guidance and only become an examiner-review incident after repetition. Technical errors are not identity evidence.
- Neither candidate is deployed. Both should advance to a prospective, consented sequential-capture pilot with pre-registered criteria while threshold 0.40 remains fixed.

Simulation limitations: still images do not reproduce temporal correlation, outages, motion, adversarial presentation, changing light or live webcam behavior; 10,000 simulations reuse finite observations and are not 10,000 independent people; alerts remain review events rather than proof.

13. Documentation alignment completed

Artifact	Alignment delivered
README.md	Current v2 architecture, JWT model, biometric lifecycle, retention, setup, testing, evaluation policy and limitations.
backend/README.md	Service/queue responsibilities, config, local commands, migrations, tests and biometric lifecycle.
frontend/README.md	Next.js 16 structure, environment, commands, exam reliability, auth behavior and tests.
performance/README.md	API/login methodology, environment controls, reproduction rules and links to retained aggregate reports.
production_readiness.md	Replaced obsolete 35%-ready assessment and already-fixed blockers with current verified status and boundaries.
task.md	Updated roadmap tracker showing completed stages, research decisions and next product work.
Phase_5_implementation_plan.md	Converted proposed exam-shell refactor into an accurate completion record.
.env.example / docker-compose.yml	Corrected database hostname to postgres; documented and wired local COOKIE_SECURE=false.

Claims policy now documented

- Tokens are described accurately as signed JWTs, with URL-safe timed signatures distinguished for email/enrollment links.
- Enrollment is described as up to five captures with at least three passing quality checks.
- Encrypted averaged templates, transient clean frames, deduplicated violation evidence and scheduled expiry are explicit.
- Only reproducible reports may support latency, scalability, FAR or FRR claims; raw screenshots and best-case runs are insufficient.
- Server timing, deterministic shuffling, auto-save/retry, asynchronous processing, snapshot expiry and PostgreSQL state are preserved as documented design strengths.

14. Known limitations, unresolved work and risk register

Priority	Open item	Why it matters	Required next evidence/action
High	Prospective biometric/session-policy validation	FEI still-image results do not represent live sequential examinations.	Consented pilot, fixed protocol, subgroup/environment reporting, human-review safeguards.
High	Production governance	Biometric and evidence processing has legal, consent, access and retention implications.	Institutional policy, DPIA/legal review as applicable, incident process, audit access review.
High	Rate limiting and abuse controls	Authentication and face endpoints can be intentionally overloaded.	Add endpoint-aware rate limits and verify under authorized load.
High	Operational resilience	Tests do not substitute for restore drills or production alerting.	Backup/restore drill, queue/database/storage alerts, runbooks, failure injection.
Medium	Face-worker scaling completion	Only one 25-student run; no 50/100 runs or reviewed aggregate report.	Repeat 25 twice more, then step to 50/100 only if acceptance criteria hold.
Medium	API performance report	Raw local CSVs show degradation but do not form a deployment capacity model.	Normalize scenarios, repeat clean runs, collect time-series resources, publish median/range.
Medium	Session risk summaries	Examiners still interpret raw accumulated events.	Design transparent risk bands and reason codes; keep human review.
Medium	Evidence export	Institutional review may need a consistent incident package.	Privacy-controlled PDF/CSV export, access logging, redaction and retention controls.
Medium	Migration directory cleanup	Stale migration paths can confuse operators despite one tested authoritative head.	Audit consumers, archive/remove legacy directories, update deployment docs.
Low	Frontend warnings	61 warnings obscure future regressions and include missing hook dependency warnings.	Resolve dependency warnings first, then unused imports/variables and intentional image exceptions.
Low	Exam entry gate size	564-line route mixes phases, camera and API behavior.	Extract entry state machine, camera hook and phase components with tests.
Low	Security headers	Broader clickjacking/CSP hardening is not yet documented as deployed.	Design Next.js 16-compatible CSP for API, WebSocket, camera and image origins; verify in browser.

Repository-state limitation

The working tree is intentionally dirty. The latest frontend refactors, documentation alignment and performance research directories are present locally but are not part of base commit 7783638d4268164d717aaa063f1519a72cef11b9. Reproducibility requires committing or otherwise preserving this exact state before treating the report as a release record.

Docker validation limitation

docker compose config --quiet crashed inside the local Docker CLI plugin with a nil-pointer panic. The YAML was independently parsed successfully with PyYAML, and no container was started or stopped. The plugin crash should not be presented as a Compose-file validation failure, but the CLI should be repaired and the command rerun before deployment.

15. Recommended next sequence

Order	Action	Completion evidence
1	Review and commit the current working tree in coherent commits.	Clean status; commit hashes recorded in report/update notes.
2	Finish 25-user face-worker repetitions; proceed to 50/100 only against pre-set thresholds.	Three comparable runs per level, resource telemetry, aggregate report.
3	Design the examiner session-level risk summary without automatic guilt conclusions.	Documented rules, reason codes, tests, human-review UX.
4	Add privacy-controlled incident/evidence export.	Authorization tests, redaction, retention/access log behavior, sample export QA.
5	Run a prospective consented repeated-observation pilot.	Pre-registered protocol, acceptance criteria, subgroup/environment limitations.
6	Complete production hardening.	Rate limiting, CSP/security headers, monitoring, restore drill, runbooks and deployment review.

Appendix A. Current changed/untracked scope

Tracked modifications at report time

- .env.example, .gitignore, README.md, docker-compose.yml, frontend/README.md, performance/README.md.
- Frontend internal readiness/task/phase documentation.
- Institution workspace route, session audit route and QuestionManager coordinator.

Untracked additions at report time

- backend/README.md.
- Institution workspace, session-audit and question-manager component directories.
- useInstitutionWorkspace, useSessionAudit and useQuestionManager hooks.
- institution-workspace, session-audit and question-manager shared types.
- performance/biometric, performance/face_worker and performance/session_policy harnesses, reports and ignored local result areas.

Appendix B. Verification commands and outcomes

Purpose	Command	Outcome
Backend	cd backend && PYTHONPATH=. ../env/bin/python -m unittest discover -s tests -v	63 passed
Frontend	cd frontend && npm test -- --run	13 passed
Harnesses	env/bin/python -m unittest performance.biometric.test_evaluate performance.face_worker.test_run performance.session_policy.test_evaluate -v	11 passed
Types	cd frontend && ./node_modules/.bin/tsc --noEmit	Passed
Lint	cd frontend && npm run lint	0 errors; 61 warnings
Whitespace	git diff --check	Passed
Compose syntax	PyYAML safe_load(docker-compose.yml)	Passed
Compose plugin	docker compose config --quiet	Local CLI plugin panic; inconclusive

Appendix C. Evidence and source registry

ID	Source	Used for
S1	ExamLoc_v2_Upgrade_Roadmap.pdf	Roadmap objectives and ten work areas
S2	README.md; backend/README.md; frontend/README.md; performance/README.md	Aligned architecture, setup, privacy, testing and publication policy
S3	backend/src/auth, exam_session, students, worker, core, db	Implemented security, timing, grading, biometrics, retention and persistence
S4	backend/tests (9 modules)	Fresh 63-test verification
S5	frontend/src/hooks, components and route coordinators	Refactoring and client reliability behavior
S6	frontend Vitest suite	Fresh 13-test frontend verification
S7	performance/results/*.csv and environment.txt	Local API/login benchmark table and environment
S8	performance/biometric/reports/fei_threshold_evaluation.md	Calibration/held-out FAR, FRR, exclusions, decision and limitations
S9	performance/face_worker/results/*/run_summary.json	Per-run isolated worker throughput and latency
S10	performance/session_policy/reports/fei_repeated_observation_evaluation.md	Aggregate policy simulation results and decision
S11	git status/log and direct file inspection	Repository state, base commit, changed scope, coordinator line counts

Appendix D. Metric definitions

Term	Definition
FAR	False accepts divided by impostor comparisons in the stated biometric evaluation.
FRR	False rejects divided by detected genuine comparisons; detector rejections are reported separately.
p95 / p99	Value at or below which approximately 95% / 99% of measured observations fall.
Queue wait	Benchmark task submission until the worker begins processing.
Processing	Image decode, detection, encoding and distance calculation in the isolated face-worker harness.
Worker end-to-end	Queue wait plus worker processing duration.
Producer-observed end-to-end	Task submission until the benchmark runner observes the result.
No-face	Detector did not find a face; operational capture/detection outcome, not a false reject denominator and not proof of identity mismatch.
Dirty worktree	Tracked or untracked local changes differ from the named Git commit.

End of report

This dossier records the current local engineering state as inspected and verified on 16 September 2026. Update it after commits, deployment changes, new benchmark levels, threshold changes, policy activation, or production-hardening work.